

Tool 4 – phish_scan.py

Phish Scan

Phish_scan.py is a python scripted email parser that evaluates emails saved in .eml format for phishing heuristics.

The problem:

Phishing emails are constant in today's computing environment. Both personal and corporate email systems do some checking on incoming emails to try and either flag them or prevent them from being delivered.

The tool:

My tool is a lightweight tool that can be used to test saved emails for phishing content. This tool can be used to check emails and as a learning tool to teach others what to look for when reading an email. I will be using this tool in my monthly security awareness class to demonstrate what to look for when reading a suspicious email.

The checks:

The tool parser checks for the following identifying characteristics of a phishing email. They include:

1. Authentication. The parser reads the authentication-results and Received-SPF headers. It flags SPF fails, DKIM (domain keys identified mail) signature failures and DMARC alignment failures. Missing headers are also flagged as there is nothing to verify.
2. Sender spoofing. Checks to see if the domain name matches the known brand name (eg. Google.com). Also checks for domain names that may look like known brand name domains (eg. Google2.com).

3. Reply-to mismatch. Compares the reply-to domain name against the from domain.
4. Link analysis. Checks to see if the visible link text matches the href points to, and notices if it points to an IP address or domain name. Checks for a suspicious TLD (top level domain) or does it look like a known brand.
5. Urgency language. Does the email contain phrases that pressure the user and create a sense of urgency.
6. Credential harvesting language. The parser looks for phrases that ask for passwords, SSNs, credit card numbers or billing details.
7. Generic greetings. Does the email contain generic greetings instead of the recipient's name.
8. Attachments. Does the email contain dangerous attachments such as .exe, .vbs, etc.
9. Reply thread. Does the email contain a Re: or Fwd: and there is no In-Reply-To or References header.
10. Missing to header. No recipient in the To: field, sometimes indicates a BCC'd mass mailing.

Each check contributes to an overall score between 0 and 100. 0 meaning a very small chance of phishing and 100 indicating a probable phishing attempt.

To run the tool:

```
Python3 phish_scan.py -help (help)
```

```
Python3 phish_scan.py saved_email.eml (single email)
```

```
Python3 phish_scan.py ./emails (check a folder of emails)
```

```
Python3 phish_scan.py saved_email.eml --csv filename (save to .csv file)
```

The tool uses pre-defined heuristics on a basic level based on domain expertise vs a model that learns patterns from data. The following heuristics are hard coded and can be modified before running the tool.

Heuristic	Example
FREE_MAIL_DOMAINS	Yahoo.com, gmail.com
COMMONLY_SPOOFED_BRANDS	Paypal, microsoft
URL_SHORTNERS	Bit.ly, goo.gl
SUSPICIOUS_TLDS	Click, link, work
URGENCY_PHRASES	Verify your account, within 24 hours
CREDENTIAL_HARVEST_PHRASES	Enter your password, enter your credit card number
GENERIC_GREETINGS	Dear customer, dear sir
DANGEROUS_EXTENSIONS	.exe, .bat
ARCHIVE_OR_DOC_EXT	.zip, .rar

Running the tool:

The tool takes a .eml file as input and produces a report on the file. Multiple email files can be placed in a folder, and the tool will parse through them one by one, reporting on each. You can also output the results to a CSV file. I am including the legit_newsletter.eml and phishing_paypal.eml in the repository. Examples are below.

One email (safe email):

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ python3 phish_scan.py legit_newsletter.eml
```

PHISH SCAN

LIKELY SAFE 0/100 [REDACTED]

Your July product update from Acme Corp
from: Acme Corp Newsletter <newsletter@acmecorp.com>
file: legit_newsletter.eml

INFO -5 SPF/DKIM/DMARC checks passed.

SUMMARY
1 email(s) scanned
LIKELY SAFE 1

```
patrickturner@PDTUbuntu:~/Desktop/tool4$
```

One email (phishing email):

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ python3 phish_scan.py phishing_paypal.eml
```

PHISH SCAN

PHISHING 100/100 [REDACTED]

Urgent: Your account will be suspended
from: PayPal Security <security@paypal-verify.com>
file: phishing_paypal.eml

HIGH +25 Display name references 'Paypal' but sending domain 'paypal-verify.com' does not match the legitimate domain (paypal.com).
HIGH +25 Link text displays 'paypal.com' but actually points to '192.168.55.2'.
HIGH +20 SPF check failed.
HIGH +20 DMARC alignment check failed.
HIGH +20 Link points directly to an IP address (192.168.55.2) instead of a domain name.
HIGH +20 Contains 7 urgency/pressure phrase(s) commonly used in phishing (e.g. threats of account suspension, deadlines, 'act now').
HIGH +15 DKIM signature verification failed.
MEDIUM +15 Reply-To domain 'totally-different-domain.ru' differs from From domain 'paypal-verify.com' - replies would go somewhere other than the apparent sender.
LOW +5 Uses a generic greeting instead of the recipient's name, common in mass-sent phishing.

SUMMARY
1 email(s) scanned
PHISHING 1

```
patrickturner@PDTUbuntu:~/Desktop/tool4$
```

All emails in a folder (next two screenshots).

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ python3 phish_scan.py ./emails
```

PHISH SCAN

```
LOW RISK 20/100 ██████████
Ernst & Young Breach Affects Personal, Financial Information
from: SecurityWeek Briefing <news@securityweek.com>
file: emails/Ernst & Young Breach Affects Personal, Financial Information.eml

HIGH +25 Link domain 'fonts.googleapis.com' looks like a lookalike of google.com/gmail.com.
INFO -5 SPF/DKIM/DMARC checks passed.
```

```
LOW RISK 20/100 ██████████
Patrick, your weekly Hannaford flyer has arrived
from: Hannaford Supermarkets <noreply@messages.hannaford.com>
file: emails/Patrick, your weekly Hannaford flyer has arrived.eml

HIGH +25 Link domain 'fonts.googleapis.com' looks like a lookalike of google.com/gmail.com.
INFO -5 SPF/DKIM/DMARC checks passed.
```

```
LIKELY SAFE 0/100 ██████████
This Is Not a Drill
from: Barnes & Noble <barnesandnoble@e.barnesandnoble.com>
file: emails/This Is Not a Drill.eml

MEDIUM +5 Contains 1 urgency/pressure phrase(s) commonly used in phishing
now').
INFO -5 SPF/DKIM/DMARC checks passed.
```

```
SUMMARY
5 email(s) scanned
LOW RISK 4
LIKELY SAFE 1

patrickturner@PDTUbuntu:~/Desktop/tool4$
```

Save to a .csv file:

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ python3 phish_scan.py ./emails --csv csvfile.csv
```

CSV file:

	A	B	C	D	E	F	G	H	I	J	K	L
path	subject	from	score	verdict	top_reasons							
emails/Ernst & Young Breach Affects Personal, Financial Information.eml	Ernst & Young Breach Affects Personal, Financial Information	news@ee	20	LOW RISK	Link domain 'fontx.googleapis.com' looks like a lookalike of google.com/gmail.com; SPF/DKIM/DM/							
emails/Patrick.your.weekly.Hannaford.flyer.has.arrived.eml	Patrick.your.weekly.Hannaford.flyer.has.arrived	noreply@	20	LOW RISK	Link domain 'fontx.googleapis.com' looks like a lookalike of google.com/gmail.com; SPF/DKIM/DM/							
emails(DEADLINE ALERT) Apply by This Friday!.eml	[DEADLINE ALERT] Apply by This Friday!	powerpar	20	LOW RISK	Link text displays 'hotmail.com' but actually points to 'na01.safelinks.protection.outlook.com'; SPF/							
emails(Unlock Your Home) Save Value with AmeriSave HELOC Solutions.eml	Unlock Your Home) Save Value with AmeriSave HELOC Solutions	hello@em	15	LOW RISK	DKIM signature verification failed.							
emails/This Is Not a Drill.eml	This Is Not a Drill	barnesam	0	LIKELY SAFE	Contains 1 urgency/pressure phrase(s) commonly used in phishing (e.g. threats of account suspensi							